

DATA SECURITY AND IT POLICY

Last Updated: January 2026

Department: Information Technology / Human Resources

Policy Owner: Chief Information Security Officer

Review Cycle: Annual

1. PURPOSE

This policy establishes guidelines for protecting company data, systems, and infrastructure. All employees must adhere to these security requirements as a condition of employment.

2. SCOPE

This policy applies to:

- All employees (full-time, part-time, contractors)
- Personal devices used for work purposes
- Company-provided devices and equipment
- All data stored on company systems, regardless of location

3. ACCESS CONTROL

3.1 Account Management

- All system access requires a unique user account
- Shared accounts are prohibited except where technically required
- Accounts must use strong passwords meeting the following requirements:
 - * Minimum 12 characters
 - * Mix of uppercase and lowercase letters
 - * At least one number
 - * At least one special character
 - * Changed every 90 days
 - * Cannot reuse the last 12 passwords
- Multi-factor authentication (MFA) is required for:
 - * All company email access
 - * VPN connections
 - * HR and payroll systems
 - * Cloud service access

3.2 Access Privileges

- Access granted on a need-to-know basis
- Manager approval required for all access requests
- Quarterly access reviews conducted by IT
- Immediate revocation upon employment termination

4. DATA CLASSIFICATION

DATA LEVELS:

LEVEL 1 - PUBLIC

- Marketing materials
- Press releases
- Public website content

LEVEL 2 - INTERNAL

- Internal announcements
- Team documentation
- General policies

LEVEL 3 - CONFIDENTIAL

- Employee personal information
- Financial records
- Customer data
- Business strategies

LEVEL 4 - RESTRICTED

- Executive communications
- M&A; information
- Trade secrets
- Security configurations

HANDLING REQUIREMENTS BY LEVEL:

Level 1: No restrictions

Level 2: Internal distribution only

Level 3: Encrypted transmission required

Level 4: Encrypted storage, access logging, additional approvals

5. DEVICE SECURITY

5.1 Company Devices

- All company devices must have:
 - * Full-disk encryption enabled
 - * Automatic screen lock (5 minutes)
 - * Current antivirus/anti-malware software
 - * Latest security patches installed within 7 days of release
 - * VPN client installed and configured

5.2 Personal Devices (BYOD)

Personal devices used for work must:

- Be registered with IT within 48 hours of first use
- Have MDM (Mobile Device Management) software installed
- Be password/PIN protected
- Have remote wipe capability enabled
- Not store Level 4 (Restricted) data locally

5.3 Lost or Stolen Devices

Report lost/stolen devices IMMEDIATELY to:

- IT Security: security@company.com
- Phone: 1-800-XXX-SECU
- HR Department

6. NETWORK SECURITY

6.1 VPN Requirements

- VPN must be connected for:
 - * Accessing company email from outside office
 - * Using shared drives remotely
 - * Accessing internal applications
 - * Any work involving confidential data
- VPN is available 24/7
- Connection timeout: 30 minutes of inactivity
- Split tunneling is disabled

6.2 Network Restrictions

PROHIBITED:

- File sharing services (Dropbox, Google Drive personal accounts, etc.)
- Peer-to-peer applications
- Cryptocurrency mining
- Unauthorized network scanning tools
- Tor browser

6.3 WiFi Security

- Office WiFi: Available to all employees, WPA3-Enterprise
- Guest WiFi: Isolated network, no access to internal systems
- Home networks: Use WPA2/WPA3 personal at minimum
- Public WiFi: PROHIBITED without VPN

7. EMAIL AND COMMUNICATION SECURITY

7.1 Email Best Practices

- Verify sender email addresses before clicking links
- Do not open attachments from unknown senders
- Report suspicious emails to security@company.com
- Use encryption for confidential data

7.2 Phishing Protection

WARNING SIGNS:

- Urgent requests for sensitive information
- Misspelled sender domains
- Generic greetings ("Dear Customer")
- Requests for password or account verification
- Suspicious attachments (.exe, .zip, .js)

IF YOU SUSPECT PHISHING:

1. Do not click links or download attachments

2. Forward to security@company.com

3. Delete the email

4. If you clicked, report to IT immediately

7.3 Instant Messaging

- Use approved platforms only (Slack, Microsoft Teams)
- Do not share confidential information in IM
- Direct message sensitive topics only when necessary

8. DATA PROTECTION

8.1 Data Handling

- Only collect data necessary for business purposes
- Store data in approved locations only
- Encrypt data before transmitting
- Delete data when no longer needed

8.2 Data Retention

- Employee records: 7 years after termination
- Financial records: 7 years
- Customer data: Per contract requirements
- Email: 3 years, then archived or deleted
- Project documentation: 5 years after completion

8.3 Data Breach Response

IMMEDIATE STEPS (within 1 hour of discovery):

- 1. Contain the breach (disconnect affected systems)**
- 2. Notify IT Security at security@company.com**
- 3. Document what happened and when**
- 4. Preserve evidence (do not delete files)**
- 5. Await further instructions**

9. INCIDENT REPORTING

REPORT IMMEDIATELY:

- Lost or stolen devices
- Suspicious emails or calls
- Unauthorized access attempts
- Malware or virus detection
- Data exposure or spills

- Social engineering attempts

HOW TO REPORT:

- Email: security@company.com
- Phone: 1-800-XXX-SECU
- In person: IT Security office
- Anonymous hotline: 1-800-XXX-TIPS

NON-RETALIATION POLICY:

Good-faith security reports will not result in retaliation. However, failure to report known security incidents is a policy violation.

10. PHYSICAL SECURITY

- Always wear your badge visibly
- Do not hold doors open for tailgaters
- Lock laptops and devices when unattended
- Secure sensitive documents in locked storage
- Report unknown visitors in office areas
- Do not discuss confidential information in public places

11. REMOTE WORK SECURITY

When working remotely, additional requirements apply:

- VPN must be connected for all work activities
- Work in private locations when discussing confidential matters
- Use privacy screens in public areas
- Do not leave devices unattended in vehicles
- Use screen blanks/locks when stepping away
- Secure home network with password protection

12. THIRD-PARTY ACCESS

- All third-party access requires IT approval
- Vendors must sign security agreements
- Access is time-limited and monitored
- No standing access for external parties

13. CONSEQUENCES OF VIOLATIONS

Violations of this policy may result in:

- Verbal warning

- Written warning
- Required training
- Loss of system access
- Suspension
- Termination
- Legal action

SERIOUS VIOLATIONS INCLUDING:

- Unauthorized access to restricted data
- Sharing credentials
- Willful negligence leading to data breach
- Retaliation against reporters

14. POLICY REVIEW

This policy is reviewed annually and updated as needed. All employees will be notified of material changes via email.

Last Review: January 2026

Next Review: January 2027

15. ACKNOWLEDGMENT

All employees must acknowledge receipt and understanding of this policy annually.

Acknowledgment is completed through the HR portal.

16. CONTACT

Questions about this policy:

- IT Security: security@company.com
- HR Department: hr@company.com
- Chief Information Security Officer: ciso@company.com

END OF POLICY